CI&T

NAVIGATE CHANGE

客户提案 · 2026 年 10 月

AI Foundation

企业 AI 的公共底座

一个账号登录所有 AI 应用；

每次调用都能追到人、算得清成本。

CI&T 方案建议书 · 基于客户现有指标平台与知识库

提案摘要

先花 3–4 周、37–55 人周，把一条链路跑成可复制的模板

3–4 周

PO 试点：登录 → Agent → 连接器 → 指标平台

37–55 人周

总投入，含 Portal 自建与两个连接器

≥2 个应用

一期接入统一登录，全部调用经网关

100% 可按人计量

模型调用留痕，成本归到部门与场景

PO 只承诺一件事：一个真实 Agent 走完登录 → 网关 → 连接器 → 指标平台这条链路，用它证明角色、审计与成本都能落到人。

人周与周期均为估算；评测中心不在本期，企业微信与 Main Agent Router 由各自团队负责。

CI&T
NAVIGATE CHANGE

四件事各自为政，代价是查不到人、算不清钱

客户已有指标平台与知识库，AI 应用和 Agent 正在增加；底座要解决的是这四件事由谁做。

今天

四套身份
AD、应用本地账号各管一摊，离职回收靠人工

权限各配一遍
渠道（DT / NKA / Ecom / MPD）与 BU 的数据范围，在每个应用里重配

Key 裸连
Key 写在应用配置里，无法统一限流、计费与审计

Agent 无台账
谁上线了什么 Agent、能调哪些工具，没有一处看得全

底座上线后

- **一次登录**
  AD 统一走 OIDC，所有 AI 应用共用一个 IdP
- **一处授权**
  Portal 起草、审批、按版本发布，出错可回滚
- **一个网关**
  LLM、MCP、A2A 都过 agentgateway，按角色放行、按人计量
- **一本台账**
  登记负责人与可用工具，统一上下线

CI&T
NAVIGATE CHANGE

底座只管公共的那四件事

AI FOUNDATION 负责

- **身份**
  AD 经 LDAP 同步，签发带 roles 与属性的 JWT
- **授权**
  每次调用核对身份、角色与工具 权限，不通过即拒绝
- **通道**
  LLM / MCP / A2A 统一经 agentgateway，按角色放行
- **连接器**
  指标平台与 KB 的 MCP 封装，Foundation 团队维护

业务系统负责

- **本体**
  指标平台、知识库、知识 Studio、业务 Agent 本身
- **权限**
  各自的角色含义、RBAC、行级与文档级权限
- **边界外**
  用户前端、企业微信、Main Agent Router
- **审计**
  系统内部的数据访问审计，由系统自己负责

接入契约：系统提供能校验用户 token 的 API 与接口文档；连接器、审计与 Trace 由底座统一做。

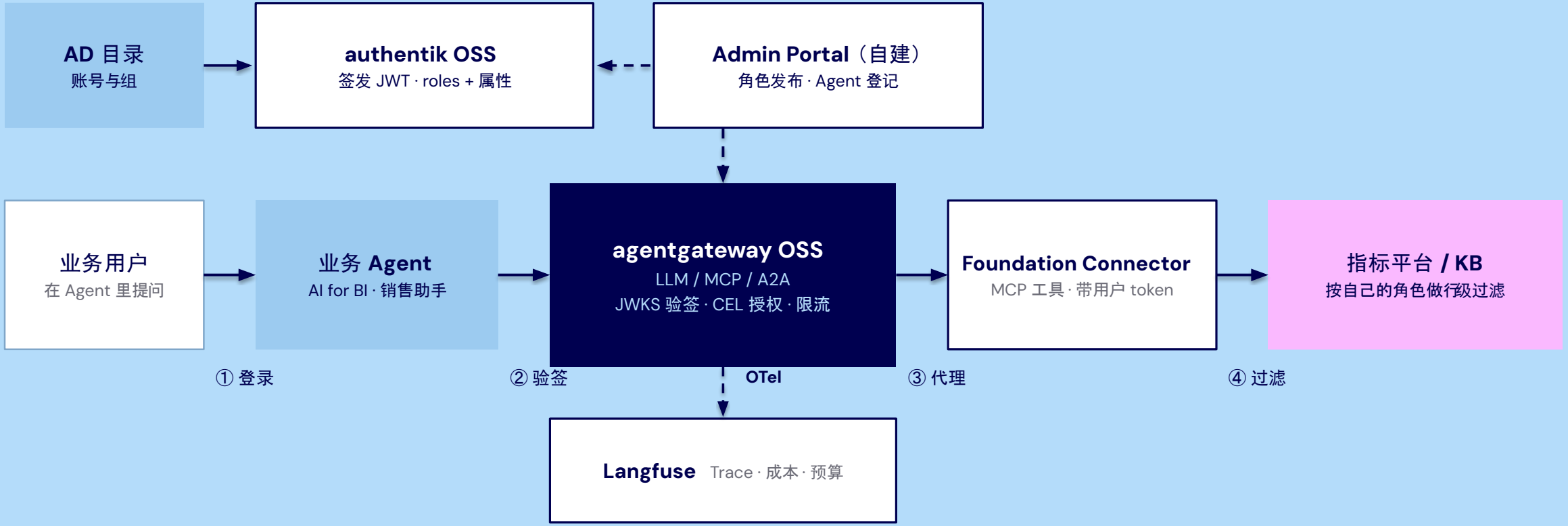
CI&T
NAVIGATE CHANGE

四条取舍，定了后面每个 设计

01	一个人一个身份	authentik 做唯一 OIDC IdP，AD 经 LDAP 同步；AD 停用即停用，离职不再靠人工回收。
02	授权中心只发事实	token 里带 roles 与属性 claim；系统内部 RBAC 不动，怎么用仍由应用决定。
03	只用社区版与 标准协议	OIDC / JWT / OTel / CRD 连接组件，换组件不用改应用，也不被许可证和报价锁住。
04	管理面收口	两个开源后台不对业务人员开放，所有变更有草稿、差异、审批与版本记录。

CI&T
NAVIGATE CHANGE

每次调用都走同一条路：登 录、验签、代理、过滤



Agent Registry 是自建的：agentgateway 本身没有注册中心；连接器属于底座，不是 业务系统的自选件。

CI&T
NAVIGATE CHANGE

三个社区版组件，加一个自建的 Portal

authentik

社区版 · MIT

统一身份

- 完整 OpenAPI v3，组可带属性
- scope mapping 可编程，可限速调用

不足：无批量成员接口，需脚本限速调用

agentgateway

v1.7 · Apache-2.0

访问网关

- 一个网关管 LLM、MCP、A2A
- JWT + CEL 直接读 jwt.roles

不足：REST 无 OpenAPI，无内置 Registry

Langfuse

开源版 · 自托

Trace 与成本

- OTel 接入，埋点统一
- Trace 与成本归集成熟

不足：需自托 ClickHouse（未验证）

Portal + Connector

自建 · FastAPI + TS

管理与接入

- 把两个后台收口成业务语言
- 审批、差异、回滚与运营视图

代价：需持续维护，是本方案的主要工作量

备选 Keycloak 只在触发条件出现时切换：PoC 里刷新后 roles 不更新，或角色组超过约 500 个，切换成本约 2–3 人周。

应用只依赖 OIDC 标准，换 IdP 不用改应用。

CI&T
NAVIGATE CHANGE

三层角色管能做什么，属性管能看哪 块

A Portal 平台角色

在 Portal 里能做什么

viewer　kb_builder　agent_dev

B 应用业务角色

由应用解释，Foundation 只负责分配

metric:viewer　metric:analyst　metric:admin　kb:reader　kb:editor

C 网关访问角色

能用哪些模型、工具与 Agent

gw:llm_basic　gw:llm_advanced　gw:mcp_metric_read　gw:agent_sales_assistant

一位 MPD 浙江销售代表的 token

```
{
  "sub": "u_10293",
  "aud": "metric-platform",
  "roles": ["viewer"],
  "gw_roles": ["llm_basic",
               "agent_sales_assistant"],
  "channel": "MPD",
  "region": "华东",
  "province": "浙江",
  "dealer_ids": ["D1023", "D1088"],
  "scope_all": false
}
```

渠道、BU、区域、经销商都做成属性：角色组不会随组织和经销商数量膨胀。

CI&T
NAVIGATE CHANGE

入职只选一个模板，其余靠 组织继承

MPD 销售代表

- metric:viewer
- gw:llm_basic
- gw:agent_sales_assistant

渠道分析 员

- metric:analyst
- kb:reader
- gw:llm_advanced
- gw:mcp_metric_read

BU 市场

- metric:analyst
- kb:editor
- gw:llm_advanced

组织继承



组上带 channel、region、province，成员进来就继承；个人只补经销商 ID 这类差异。

一人一角色会到 200–600 个角色组、token 超 4 KB；属性方案约 30–60 个。

CI&T
NAVIGATE CHANGE

改一次角色，30 分钟内生效，也能退回上一版

1

起草

在 Portal 改草稿：手工、导入 Excel，或从 HR / M2 拉差异

2

差异预览

按人列出 +角色 / −角色 / 属性变化，标出高风险项

3

审批

审批人 ≠ 起草人；高风险项需安全工程师会签

4

发布

调 authentik API 逐个改组成员与属性，生成版本号

5

生效与回滚

下次刷新 token 时生效；回滚 = 反向差异，同样走审批

改草稿 → 发布	发布 → 进入 **token**	紧急情况
1000 条变更约 2–5 分钟	下次刷新，15–30 分钟	让用户重新登录，立即生效

一次真实发布：11 月辖区调整

M2 给出新辖区表：37 名代表换经销商、2 名调华南、0 个角色变化。Portal 导入生成 v2026.11，大区经理确认、审批后于 10 月 31 日 22:00 发布，约 1 分钟写完；次日上班即为新范围。

CI&T
NAVIGATE CHANGE

华东经理问 sell-in，每一跳都带着他的 token

01 登录
登录 AI for BI，token 带区域经理角色与 region=华东

02 动议
Agent 调 metrics.query，带用户 token 请求网关

03 验签
网关 JWKS 验签，CEL 查 jwt.roles；不通过即拒绝

04 代理
转给指标平台 Connector，记审计，带 token 调 API

05 过滤
指标平台按 region=华东 过滤，只回华东六省

TRACE · 一次调用

用户	张 · 华东大区
Agent	AI for BI
工具	metrics.query
参数	region=华东 · 2026-09
返回	200 · 1.4 s · 6 行（华东各省）
成本	¥0.02（示例）
身份	user token 直传 · 无服务账号

任何一跳被问到这是谁查的，答案都是张经理本人的 token，不是应用的服务账号。

CI&T
NAVIGATE CHANGE

PO 只承诺一条链路和一个 Agent

PO · 试点

3–4 周

- AD 接入 authentik，签发带角色的 token
- 网关 + 指标平台连接器上线
- 跑通 登录 → Agent → 连接器 → 指标平台
- 1 个真实 Agent 验证角色与属性

一期 · 扩面

按应用排期

- 全部目标应用接入统一登录
- 角色模板、版本发布与审批
- KB 连接器接入
- 运营中心：用量、成本、审计

二期 · 按需

触发条件出现再排

- 跨系统身份透传（Token Exchange）
- 更多 Agent 登记与工具授权
- 通用连接器模板对外交付
- 评测中心（不在本期）

PO 结束只看一件事：那条 链路有没有在真 实数据上跑通。角色模型的复 杂度留到一期，看真 实反馈再收敛。

CI&T
NAVIGATE CHANGE

四个已知风险，每个都写好了触 发条件

风险	触发条件	回退动作
身份方案要 换	刷新后 roles 不更新，或角色组超过约 500 个	切 Keycloak：应用只依赖 OIDC，不动，约 2–3 人周
Token Exchange 未就绪	authentik 正式版不支持 RFC 8693	一期直传用户 token，二期再切；兜底方案 C 需系统方书面确认
角色发布排长队	1000 条变更的审批与执行窗口超时	模板 + Excel 批量 + 限速执行，发布放夜间窗口
token 撑爆请求头	有人带几百个经销商 ID，payload 超 4 KB	一律属性化；超过约 20 个经销商走 scope_all 或按 user_id 查

另外两处未验证：组属性合并的精确规则以 PoC 为准；内容护栏能力范围需随试点确认。

CI&T
NAVIGATE CHANGE

04 · 待确认

六件事定了，角色模型才不用返工

都不影响 PO 启动；但会决定一期要不要改组织组与属性。

01 M2 的含义

是不是经销商与销售辖区的主数据？决定 dealer_ids 从哪来。

02 MPD 是否严格三级

总部 → 大区 → 省区，决定组织组与属性继承。

03 BU 要不要按渠道再切

决定属性维度数量与统计口径。

04 Prof MKT 与 TMKT

是不是同一个 BU 值？影响 bu 的取值。

05 外部人员

经销商账号本期纳不纳入？纳入要独立 IdP 源与前缀。

06 跨 BU 人员

bu 输出数组，还是建跨 BU 市场模板并会签？

建议放一次 2 小时工作坊拍完，PO 期间同步确认。

CI&T
NAVIGATE CHANGE

下一步

THANK YOU.

先选一个真实 Agent。

3–4 周后，我们带着跑通的链路和一本能对上人的账回来。

建议的下一步

① 定试点 Agent 与指标口径　② 确认 M2 与组织结构　③ 排出两个连接器的接口人

CI&T
NAVIGATE CHANGE

附录 A

连接器只封装业务动作，不开放 SQL

工具清单

metrics.query(指标, 维度, 时间)
按业务动作取数，后端按 token 过滤

metrics.list_metrics()
列出当前角色可见的指标

kb.search(问题, 空间)
按知识空间与密级检索

kb.get_doc(文档 ID)
取文档，权限由 KB 判定

新系统接入五步

1. 系统提供能校验用户 token 的 API 与文档
2. 用通用框架生成 连接器骨架：认证、透传、错误、审计已内置
3. 定义工具清单与所需网关角色
4. 在 Portal 登记并发布
5. 联调与验收，接入用量与成本看板

每个系统一个 MCP Server，Streamable HTTP，部署在 agentgateway 之后，不对 Agent 直接暴露；401 / 403 原样映射为「无权限」，不重试、不降级为服务账号。

CI&T
NAVIGATE CHANGE